
Data Governance Plan

Miroir

B2B SaaS platform for image consulting

Néhémie

Executive summary

Miroir is a software company that has been on the market for eighteen months, with a team of fifteen today. Its customers are image consultants: professionals who advise their own clients on how to dress, and who turn to Miroir because it lets them prepare a styling proposal in minutes rather than hours. The platform ranks a handful of relevant pieces out of a catalogue of tens of thousands, and the consultant makes the final choice.

That speed has a consequence. To recommend well, the platform holds data belonging to the consultants' clients, third-party individuals Miroir never deals with directly, and that data carries different levels of sensitivity, from a budget bracket to body measurements. This is the reason the company needs a data governance process: so that the data the platform manages can be trusted, traced and kept intact, for every person it concerns. The business case is direct. A consultant will not place third-party client data into a tool whose handling they cannot trust, and an investor will not commit to a company that cannot demonstrate that handling. Lose that trust and customers leave; for a young company, that is what bankruptcy looks like. Governance is not an administrative layer here, it is a condition of staying in business.

Because Miroir is a small company, its governance question spans both data and the AI models that consume it. This plan focuses on the data, and treats AI governance as a related discipline in its own right, to be developed as the company grows. Its recommendations are shaped for Miroir rather than borrowed from a larger template: a single governance body owns the policy and holds people accountable through clearly allocated roles; data is handled under explicit rules across its whole life, with quality enforced automatically rather than by hand; compliance and risk are treated together, with the same roles answerable throughout; change is managed as much in process as in training; and a dated roadmap brings the whole thing into being, measured against a small set of concrete targets. The sections that follow set out the business context, the policy, the data and its handling, compliance and risk, the change to manage, and finally the governance body itself, presented last so that it reads as the conclusion the rest of the document builds towards.

Contents

Executive summary	2
1 Business context and the governance opportunity	4
2 Policy and guiding principles	5
3 Data lifecycle and quality	5
4 Compliance and risk	7
4.1 GDPR in practice	7
4.2 Fairness and inclusion	8
4.3 Risk map and incident response	8
4.4 Auditability	9
5 Change management	10
6 Governance body and roadmap	10
6.1 The governance body	10
6.2 Roles and accountability	11
6.3 Indicators	13
6.4 Roadmap and maturity	13

1 Business context and the governance opportunity

Miroir sells software to image consultants. The consultant is the customer; the people the consultant dresses are the end clients, and the platform never deals with them directly. A consultant typically manages around thirty premium clients and, before Miroir, spent most of each session searching online catalogues by hand, applying rules of colour and body shape across thousands of items from memory. Miroir replaces that search. From a client's profile and the occasion, the platform returns a short, ranked shortlist out of 44,419 catalogue items, and the consultant makes the final selection. The machine does the searching; the consultant keeps the judgement, and every decision is logged so the system keeps improving. The company runs on a team of fifteen, a technical group around the CTO and a product-and-business group around the CEO, and the governance described here is sized to that reality.

To recommend, the platform holds four kinds of data, and they do not carry the same risk.

- **End-client profiles** (colour season, body shape, style archetypes, budget, size) are personal, and body measurements can edge into the special-category territory of the GDPR.
- **Usage signals**, the consultant's keep-or-discard decisions, are behavioural data tied to a pseudonymised client, and they feed the weekly retraining.
- **The product catalogue**, drawn from a public dataset with its image embeddings, is non-personal but bound by intellectual-property terms.
- **The ML models**, the re-ranker artifacts versioned in the model registry, are business assets whose behaviour must stay documented and accountable.

Treating these four as one undifferentiated pool would be the first governance mistake, and the plan keeps them distinct throughout.

Governance here is not only a shield against those risks, it is also an opportunity. A well-kept data catalogue lowers the cost of every new feature, because the team can find and reuse data safely, and it lets the company state with evidence what it holds and why. For a business whose entire value rests on handling other people's client data well, the governance maturity it can show becomes part of the product, and part of what a due-diligence audit examines before any fundraising. Doing this while the team is small is far cheaper than retrofitting it later. The stakes are therefore business stakes before they are technical ones: customer trust, regulatory standing, the soundness of the models, and the ability to raise capital. Investors in this space increasingly ask to see how data is governed before serious talks begin.

2 Policy and guiding principles

The reason Miroir needs data governance follows directly from its business. The company promises that data entrusted by a consultant is used to recommend, protected by default, deleted when its purpose ends, and never resold. Everything in this plan exists to make that promise verifiable rather than merely stated. The policy applies to the four data families above and to the pipeline that turns them into recommendations. Internal HR data, accounting, and prospect data are deliberately out of scope, each governed by its own policy.

Five principles settle any trade-off where no specific rule applies.

1. **Human final decision.** Nothing reaches an end client automatically. The model suggests, the consultant chooses, and this cannot be switched off.
2. **Minimisation.** If a field is collected, the company can say why. Optional attributes earn their place only when they are shown to improve recommendations.
3. **Traceability by default.** Anything that ships to production, a model, a schema, a policy, leaves a written trace in the repository as a signed decision record.
4. **Instrumented quality.** Data quality is enforced inside the pipeline, not signed off by eye. An automated gate stops a retraining run on bad data, with no manual override.
5. **Transparency.** The served model carries a public model card stating what it does, where it fails, and what it was trained on, updated at every promotion.

The regulatory framework is set out here, once, and referenced from nowhere else in the document. The **GDPR** and the French Data Protection Act govern client profiles and usage signals: lawful basis, retention, and the rights of the people concerned. The **AI Act** classifies the recommendation system as limited-risk, which brings duties of transparency and documentation rather than the heavy obligations reserved for high-risk systems. The **Consumer Code** covers pre-contractual information and algorithmic transparency. Other frameworks were considered and set aside with reason: the platform is not an essential entity under NIS2, body-shape data does not amount to health-data hosting, and the ISO 27001 certification is a second-year target rather than a present obligation.

3 Data lifecycle and quality

The same data is governed across its whole life, and each stage carries its own rule.

Stage	Rule
Collection	By the consultant, after explicit end-client consent on a timestamped form.
Storage	Encrypted at rest, with tenants isolated from one another by row-level security enforced in the database rather than in application code.
Processing	Versioned pipelines only; no data leaves towards any third party that is not named in the register.
Archival	After twelve months of client inactivity, data moves to a restricted archive.
Deletion	On request, effective within thirty days including backups, with a deletion certificate issued.

Each level of data carries controls proportionate to its sensitivity:

- **Restricted** (an identified profile with body measurements): encrypted, access-logged, and masked outside production.
- **Confidential** (pseudonymised signals): encrypted, with access logged.
- **Internal** (catalogue, embeddings, model cards): available to the team and versioned.
- **Public** (product documentation): no specific control.

Quality is not asserted, it is measured. Automated expectations check the data on every run, and a run on data that fails those checks does not proceed. The results of these checks are themselves recorded, which is what lets the company prove rather than claim that what it serves is sound. This is also where auditability begins: because every check leaves a trace, a quality measurement can be reconstructed after the fact, which is precisely what an auditor, or an investor, will ask to see.

The data catalogue underpins all of this, and it is more than a control. Kept in the repository alongside the code, it documents every table and column by owner, source, update frequency and sensitivity, so the team can find and reuse data without guesswork. That makes the catalogue a business enabler as much as a governance artefact: it shortens the path from idea to new feature, and it fixes the meaning of the data in one place, so that a term such as *archetype* or *session* means the same thing to everyone who uses it.

4 Compliance and risk

Compliance and risk are treated as a single subject, because at Miroir's scale they are answered by the same controls and the same people.

4.1 GDPR in practice

Miroir's role under the GDPR is not the same for every kind of data, and the plan states it activity by activity, because the law assigns responsibility to whoever decides the purpose of a processing, not to whoever holds the commercial relationship. For the end-client data a consultant entrusts to the platform, the consultant decides why and how, so the consultant is the controller and Miroir is the processor acting on documented instructions under Article 28. For the consultant accounts and billing it runs for itself, Miroir decides the purpose and is therefore the controller in its own right. Keeping these two hats distinct is what protects the company: a processor that strays beyond instructions is treated as a controller for that processing and loses the protection the status gives.

On that basis, the lawful basis is explicit consent for end-client profiles, renewable and revocable, and legitimate interest for pseudonymised signals, backed by a balancing test. The external DPO keeps the processing register and runs every request from a data subject, access, rectification, erasure, portability or objection, through a single channel, answered within a fifteen-day target against the thirty-day legal cap. Privacy is built in by default rather than added on: a profile is visible only to its own consultant through row-level security, optional fields are withheld until proven useful, and bulk export is disabled in the interface and requires a logged request to the DPO. Sub-processors are bound by data-processing agreements, and cross-border transfers are avoided by default; where one becomes necessary it is preceded by an analysis and a valid transfer mechanism. The register itself holds four processing activities:

Processing	Legal basis	Retention
Client profiles	Consent	12 months after the last session, then a 6-month archive, then deletion
Usage signals	Legitimate interest	24 months, pseudonymised
Consultant ac-counts	Contract	Duration of the contract, plus 5 years
Technical logs	Legitimate interest	6 rolling months

Under the AI Act, the limited-risk classification obliges Miroir to tell end clients that a recommendation is AI-assisted, to publish system documentation (the model card serves this purpose), and to retain operational logs. The heavier obligations placed on high-risk systems do not apply, as the system does not operate in the domains the regulation lists as high-risk. This qualification is documented and re-examined at every major change.

4.2 Fairness and inclusion

Inclusion is part of compliance here, not a separate courtesy, because Miroir serves a clientele spread across Europe and Africa. The public catalogue used to train the model leans Western, so left unchecked the recommendations could serve some skin tones, body shapes and cultural dress codes better than others. This is tracked through fairness slicing, with performance measured separately across colour-season and morphology groups and fed back into retraining, and the current limit is stated honestly in the model card: the bootstrap data is not yet representative, and real consultant feedback is what will close the gap. The same concern runs through language, with profiles, labels and the delivered board maintained in French and English over one normalised vocabulary, and through accessibility for the end client, whose board meets recognised contrast standards, carries text alternatives for every image, and can be exported in a screen-reader-friendly form on request.

4.3 Risk map and incident response

The risks that matter are specific to this business, and each is owned by a named role, the same role that appears in the governance section and in the RACI, so that accountability can be followed from one end of the document to the other.

Risk	Likeli.	Impact	Owner	Main treatment
Client-profile leak	Medium	Critical	DPO	Encryption, isolation, masking, pen-tests
Multi-tenant failure	Medium	Critical	CTO/CDO	Row-level security, isolation tests, audit
Bias from the bootstrap	High	High	Data Owner, Models	Model card, fairness slicing, human oversight
Ransomware	High	Critical	CISO	Immutable backups, EDR, recovery drills
Poor input quality	High	High	Data Owner, Signals	Quality gate, drift monitoring, rollback
Internal error or misuse	Medium	High	CTO/CDO	Least privilege, logging, separation of duties

Likelihood and impact are reviewed once a year, informed by the year's incidents, and a treatment is chosen to bring each risk down to a level the governance body is willing to accept, written down rather than left to instinct. When an incident does occur it is qualified within two hours by the CTO/CDO; past the notification threshold the DPO triggers the regulator's procedure within seventy-two hours and informs the people concerned where required. The crisis cell handles communication and remediation, and a written post-mortem closes the case and updates this map.

4.4 Auditability

A company of fifteen has no audit department, so Miroir audits itself the way well-run small companies do, in three layers that cost almost no extra headcount. The **code** is the first: releases pass automated tests, a retraining run passes its quality gate or it does not run, and access rights are checked against a baseline, none of which waits for an auditor and none of which can be quietly skipped. The **written trail** is the second: decisions live as signed records in the repository, model versions and promotions in the registry, lineage in the pipeline tools, so anyone can reconstruct who decided what, when, and on which data. The **human review** is the third: once a year the DPO and CTO/CDO trace a sample of real cases end to end, one rights request honoured, one deployment traced, one deletion verified down to the backups, with an external audit brought in at eighteen months ahead of the ISO 27001 target.

5 Change management

Putting this plan in place changes how people work, not only what they know, which is why it is handled as change management rather than training alone.

The training itself is anchored to the moments when a data decision is actually made. On joining, everyone follows a short path covering the policy, the basics of the GDPR and the AI Act, the incident procedure, and tenant isolation. Technical staff add a module on application security and on handling data outside production; sales and product staff cover compliance in demonstrations, prospect data, and the controller-side duties that fall on consultants. An annual refresher carries the year's incidents and the lessons drawn from them, and a short quiz closes each session to confirm the material has landed.

The deeper change is in the processes. Consent capture becomes a step in client onboarding rather than an afterthought; a rights request follows a defined route with a known owner and deadline; and a deployment is not considered done until its decision record exists. Materials are built to be accessible, with subtitling, recognised contrast standards and screen-reader support, and staff who declare a disability receive an individual adjustment, extended time or adapted support, coordinated by the people responsible for them. Effectiveness is judged less by the quiz than by the number of avoidable incidents over the year, which is the measure that actually reflects whether behaviour has changed.

6 Governance body and roadmap

With the problems set out, the plan closes on the body that owns them and the roadmap that brings it to life. This final section is both the control tower and the execution engine, placed last on purpose so that the recommendation follows from the work rather than preceding it.

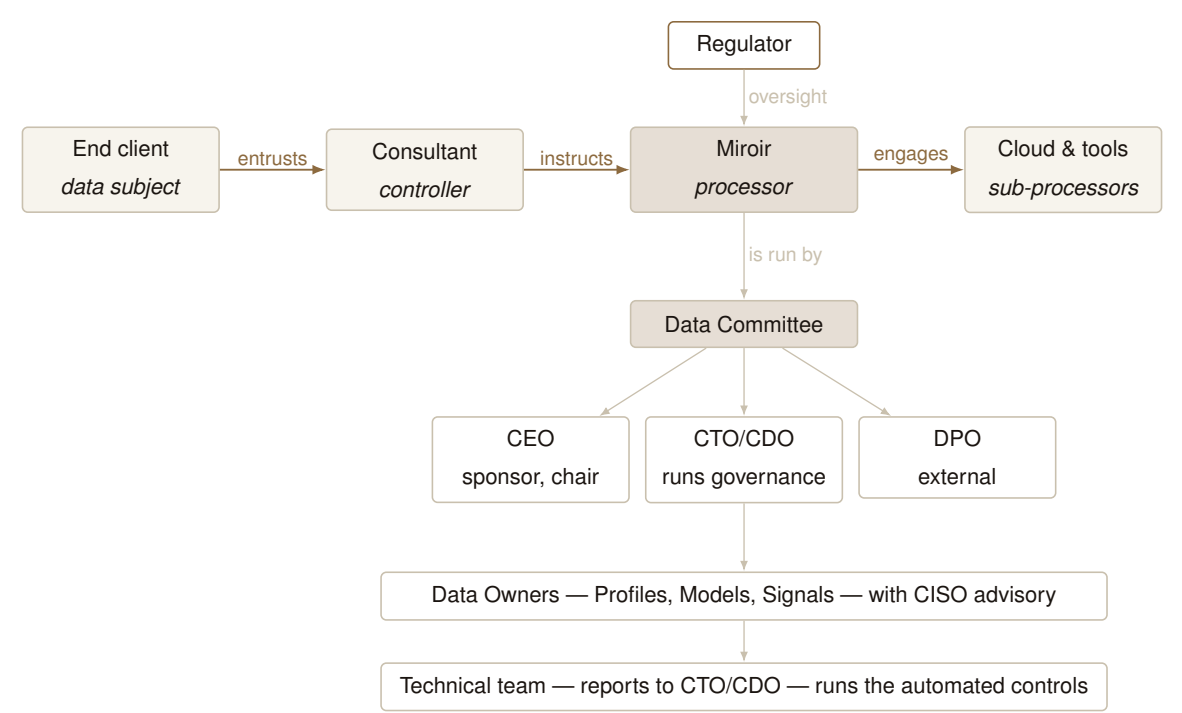
6.1 The governance body

In its first year Miroir runs governance from a single table. The **Data Committee** is the standing body: the CEO chairs it as executive sponsor, the CTO/CDO runs it as Chief Data Officer, and the external DPO sits on it. It meets monthly and works a running agenda, any incidents, the governance indicators, client requests to see or delete their data, model promotions, and changes to the register, with minutes kept for audit. A **quarterly review** brings in the fractional CISO and a rotating Data Owner for structural decisions such as new data domains, partnerships, or tooling. A **crisis cell** of CEO, CTO/CDO, DPO and external

counsel activates within two hours of a breach.

The body is small by design. Fifteen people cannot staff a federated structure, so one committee owns every data decision, and the CTO doubles as CDO because splitting the two at this size would be a title with no one behind it. The technical team reports to the CTO/CDO, and the federated model switches on when real headcount, not the calendar, can support it.

Governance, though, is not only an internal matter. The data the platform protects belongs to people Miroir never meets, and the figure below shows both faces of that. On the outside is the chain of responsibility the GDPR draws around the data; on the inside, the body that runs the controls day to day. The end client is the data subject; the consultant, who decides why the data is collected, is the controller; Miroir, acting on the consultant’s instructions, is the processor; and the cloud and tooling vendors Miroir relies on are sub-processors, with the regulator overseeing the chain. Reading the diagram from top to bottom means asking *whose data is this and who answers for it* before *who operates the controls*.



Coloured arrows trace the GDPR chain of responsibility; grey lines, the internal reporting that runs the controls.

6.2 Roles and accountability

The same role names used in the risk map run through the table and the RACI below, so that a reader can follow a single role across the whole document.

Role	Responsibility
CEO	Executive sponsor; chairs the committee; carries the policy to the board and investors; accountable for major incidents.
CTO/CDO	Runs governance; owns the data architecture; signs decision records; approves model promotions; manages the technical team.
DPO (external)	GDPR compliance, the register, rights requests, the regulator relationship, impact assessments.
CISO (advisory)	Security audits twice a year; validates access management and encryption.
Data Owners	Approve usage and changes for their domain (Profiles, Models, Signals); own the matching risks.
Technical team	Implement the controls, maintain the pipelines, execute decision records; report to the CTO/CDO.
Consultants (external)	Controllers for their own clients' data; Miroir is their processor under Article 28. They sit outside the internal matrix below.

Activity	CEO	CTO	DPO	CISO	Own.	Team
Define the data policy	A	R	C	C	C	I
Classify data	I	A	C	I	R	R
Manage GDPR compliance	I	C	A/R	C	C	I
Handle a rights request	I	I	A/R	I	C	R
Approve a model promotion	I	A	I	I	R	R
Secure access	I	C	C	A/R	I	R
Manage people	A	R	I	I	I	I
Manage a major incident	A/R	R	R	C	I	R

R Responsible A Accountable C Consulted I Informed

6.3 Indicators

The governance body measures itself against five targets, reported monthly as a one-page dashboard. A target missed for two consecutive months triggers a focused review with an owner and a deadline, and the indicators themselves are revisited each year.

Indicator	Year-1 target	Source
Valid consents on active clients	$\geq 98\%$	Profile base
Average response to data requests	≤ 15 days	DPO
Retraining runs blocked on quality	$\leq 5\%$	Pipeline
Automated test coverage	$\geq 80\%$	CI
Staff completing the yearly path	100%	DPO

6.4 Roadmap and maturity

The roadmap connects this body to dated milestones rather than leaving it as an intention.

By	Milestone	Owner
Day 15	External DPO retained	CEO
Day 30	Register and rights procedure live	DPO
Day 45	Profile impact assessment complete	DPO, CTO
Day 60	Tenant isolation audited and tested	CTO, CISO
Day 90	First committee review; year-1 plan set	CEO, CTO
Month 18	External audit; ISO 27001 track opens	CTO/CDO

Against a five-level maturity scale, from initial to optimised, Miroir today sits at *managed* on strategy, organisation and culture, and between *defined* and *measured* on policy, process and tooling, where the automation is strongest. The year-one target is to reach *defined* to *measured* across every axis, without unrealistic over-investment; moving to *optimised* on process and tooling depends on fundraising and on hiring a dedicated data steward. The committee reviews this plan once a year, and off-cycle on any material change, a new regulation, a significant incident, crossing roughly twenty employees, or a shift in scope. That review is also where the next chapter opens: the federated model, the data steward, and AI governance taken up as a discipline in its own right.